

Security Policy and Procedures

LAST UPDATED: AUGUST 18, 2026

This document describes the security practices that govern MĪZAN (app.mizan.exchange), a personal finance dashboard that aggregates bank, brokerage, and market data via Plaid, SnapTrade, and related read-only APIs.

1. Scope

This policy covers:

- All systems that store, process, or transmit consumer financial data obtained via Plaid or SnapTrade.
- Administrative access to production infrastructure (Vercel, Supabase, GitHub, Plaid Dashboard, SnapTrade Dashboard, Anthropic Console).
- All code, configuration, secrets, and operational practices used to run the deployed application.

2. Governance

The operator is responsible for information security, including:

- Policy ownership and review.
- Vendor risk assessment for any new third-party data processor.
- Incident response and breach notification.
- Maintaining the access control matrix.

Policy is reviewed **quarterly**, or whenever a material change in infrastructure, vendors, or data flows occurs — whichever is sooner. The review is scheduled automatically rather

than by memory: an automated check reads this document's own review date daily and notifies the operator once the interval has elapsed.

3. Identity and Access Management

3.1 Production system access

- All administrative accounts (Vercel, Supabase, GitHub, Plaid, SnapTrade) require multi-factor authentication.
- Production secrets (Plaid client ID and secret, Supabase service-role key, SnapTrade consumer key, Anthropic API key, third-party API keys) are stored in Vercel environment variables, scoped per environment (Development, Preview, Production), and never committed to source control.
- Principle of least privilege: the public-facing application uses the Supabase anonymous key with Row-Level Security policies. The service-role key (which bypasses RLS) is used only on the server side and never transmitted to the browser.

3.2 Consumer access

- End users authenticate via Supabase Auth (email + password).
- Multi-factor authentication (TOTP) is available to end users through the in-app account settings.
- Sessions use Supabase-issued JWTs; the server validates the JWT on every request that touches consumer financial data.
- Row-Level Security (RLS) policies enforce that each authenticated user can read only their own rows in Supabase tables.

4. Infrastructure and Network Security

- **Encryption in transit:** TLS 1.2 or better is enforced for all client-to-server traffic via Vercel. HSTS is set in response headers.
- **Encryption at rest:** Supabase Postgres uses AES-256 disk-level encryption. SnapTrade user secrets are additionally encrypted at the application layer (AES-256-GCM) before storage.

- **Secret storage:** All API credentials are managed via Vercel encrypted environment variables. No secrets exist in the source repository.
- **Content Security Policy:** A strict CSP is set via `vercel.json`, including explicit allowlists for Plaid and SnapTrade origins.
- **Security headers:** `Strict-Transport-Security`, `X-Content-Type-Options`, `X-Frame-Options`, `Referrer-Policy`, and `Permissions-Policy` are set on all responses.
- **Rate limiting:** Database-backed per-user and per-IP rate limits apply to authentication and data endpoints. Repeated authentication failures from one address trigger a temporary block.

5. Development and Vulnerability Management

- **Dependency scanning:** GitHub's automated dependency security alerts (Dependabot) are enabled. Vulnerable dependencies are reviewed and patched on receipt.
- **Patch management:** Upstream package updates are applied through standard `npm` workflows. Production deploys go through Vercel CI.
- **Automated testing:** A unit and end-to-end suite runs against the production build before release, including checks that published policy statements match the system's actual behaviour.
- **Runtime monitoring:** Sentry captures and alerts on backend exceptions and frontend errors in production, with personally identifying information scrubbed.
- **Anomaly detection:** Automated detectors monitor authentication failure spikes, provider error-rate spikes, scheduled job staleness, upstream data-feed failures, credential misconfiguration, and new-device sign-ins, with email alerts.
- **Audit logging:** Every security-relevant event (login, MFA enrollment, bank connect, bank disconnect, session revoke, account deletion) is recorded to an append-only `audit_log` table.

6. Privacy and Data Handling

Refer to the [Privacy Policy](#) for the full data-handling disclosure to end users, and the [Data Retention Policy](#) for retention periods by category.

6.1 Data categories

- **Authentication data:** email, hashed password (via Supabase Auth), optional TOTP factor.
- **Plaid access tokens:** stored server-side only in `plaid_tokens` (RLS-protected, never returned to the browser).
- **Plaid account metadata:** institution name, account name, masked number, current and available balances, currency. Stored in `plaid_accounts` with RLS.
- **Plaid transactions:** stored in `plaid_transactions` with RLS, synced incrementally via `/transactions/sync`, so that budgets, spending history and recurring-payment detection persist across sessions.
- **SnapTrade user mapping:** opaque user-id and user-secret pair per Supabase user, stored encrypted in `user_snaptrade`.
- **Product usage counters:** a per-user view count per navigation destination in `nav_usage`. Counters only — no timeline, no financial data, no IP or device details.

6.2 Consent

- End users consent to data collection at signup (acceptance of the Terms of Service and Privacy Policy).
- Plaid Link's own consent flow obtains explicit consent for each institution linked, with the user retaining the ability to disconnect at any time.

7. Incident Response

If the operator becomes aware of a confirmed or suspected security incident affecting consumer financial data:

1. Contain the incident (revoke tokens, rotate credentials, take affected systems offline).
2. Investigate scope and root cause using Sentry, audit logs, and Vercel/Supabase access logs.
3. Notify affected users without undue delay and in accordance with applicable law.
4. Notify Plaid and SnapTrade where their data or systems are implicated.
5. Document the incident, remediation, and lessons learned.

8. Vendor Risk

The following third parties process or store consumer data on behalf of MĪZAN. Each is reviewed for SOC 2 / ISO 27001 / equivalent attestation and a published security policy before integration:

- **Vercel** — hosting, edge network, function execution.
- **Supabase** — Postgres database, authentication, RLS enforcement.
- **Plaid** — bank aggregation.
- **SnapTrade** — brokerage aggregation.
- **Anthropic** — AI Assistant. Portfolio context is sent only when the user sends a message to the Assistant.
- **Sentry** — error monitoring (PII scrubbing enabled).
- **Resend** — transactional email.

9. Contact

Security questions or vulnerability reports: khanstyle02@gmail.com.

For end-user data requests (access, deletion, correction), refer to the contact channel listed in the [Privacy Policy](#).